



NAME	HIDYANSH VARSHNEY
ROLL NO.	2414500172
PROGRAMME	BCA
SEMESTER	4 th
SUBJECT NAME	Introduction To Network Security
SUBJECT CODE	DCA2208

SET – I

Question [1]. What is trust management in network security?

Explain its importance with suitable examples. Explain the fundamental objectives of network security and how they help protect data in modern networks.

➤ **Trust Management in Network Security**

Trust management in network security is the process of establishing, evaluating, and maintaining trust relationships between different users, devices, and systems within a network. It defines rules and policies that determine who or what is allowed to access which resources, and to what extent — based on their identity, behavior, and context rather than just their location inside or outside the network.

Traditional networks assumed that anyone inside the network perimeter could be trusted. This assumption proved dangerous as insider threats, compromised accounts, and sophisticated attacks became common. Modern trust management moves away from this. A well-known approach built on this idea is Zero Trust Architecture, which operates on the principle of 'never

trust, always verify.' Every access request — even from someone already inside the network — is verified before being granted.

For example, consider a government office where employees access classified files remotely. Trust management checks whether the employee is who they claim to be (using multi-factor authentication), whether their device meets security standards (no outdated software), and whether the access request fits their normal work pattern (logging in from an unusual country at midnight would be flagged). Only if all conditions are satisfied is access granted, and even then, only to the minimum required data.

➤ **Importance of Trust Management**

Trust management is critical because threats no longer come only from outside — a significant number of security incidents are caused by insiders, whether through negligence or malicious intent. Without proper trust controls, a single compromised employee account can expose the entire organization's data.

It enforces the principle of least privilege — users get access only to what they absolutely need for their work, and nothing more. This limits the blast radius of any breach. For example, a junior accountant should not have access to executive payroll records just because they work in the finance department. Trust management ensures such boundaries are maintained automatically.

It also enables dynamic access control — permissions can be adjusted in real time based on changing conditions. If an employee's behavior suddenly becomes unusual, such as downloading large volumes of sensitive files after office hours, the system can automatically reduce their access or trigger an alert. This real-time adaptability makes trust management far more effective than static access lists that are reviewed only occasionally.

➤ **Fundamental Objectives of Network Security**

Network security is guided by a core set of objectives that together ensure data and systems are protected from threats. These are commonly grouped as the CIA triad — Confidentiality, Integrity, and Availability — along with Authentication and Non-repudiation.

Confidentiality ensures that data is accessible only to those who are authorized to see it. Sensitive information like medical records, financial details, or strategic business plans must be kept away from unauthorized users. Encryption is the primary tool for maintaining confidentiality. When data is encrypted, even if intercepted during transmission, it cannot be read without the decryption key. For example, when you check your bank account online, the connection is encrypted using HTTPS so that no one monitoring the network can read your account details.

Integrity ensures that data remains accurate and unaltered during storage and transmission. If an attacker modifies a payment instruction — changing the recipient account number — the damage could be severe. Hash functions and digital signatures are used to detect any such tampering. If even a single character in a file changes, the hash value changes completely, immediately revealing that the data has been modified.

Availability ensures that systems and data are accessible to authorized users whenever they need them. Denial of Service (DoS) attacks specifically target availability by flooding a server

with fake requests until it crashes and cannot serve real users. Network security measures like traffic filtering, rate limiting, and redundant servers help maintain availability even under attack.

Authentication verifies the identity of users before granting access. Passwords, OTPs, biometrics, and smart cards are all authentication mechanisms. Non-repudiation ensures that a user cannot deny having performed an action — for example, a digitally signed contract cannot be later claimed as unsigned. Together, these objectives form the complete foundation of modern network security, protecting data at every stage of its lifecycle.

**Question [2]. What is correlation and traceback in network attacks?
Explain their role in identifying attackers. Compare active and passive attacks in network security with suitable examples.**

➤ **Correlation in Network Attacks**

Correlation in network security is the process of analyzing and connecting multiple security events from different sources to identify a meaningful pattern or a coordinated attack that would not be visible by looking at any single event alone. Modern networks generate thousands of log entries, alerts, and events every minute — most of which are harmless in isolation. Correlation connects the dots between these events.

For example, an intrusion detection system might log three failed login attempts on a server. Separately, a firewall might record an unusual port scan from the same IP address. The email gateway might also flag an unusual attachment received around the same time. None of these events individually triggers a major alarm. But when a correlation engine connects all three, it reveals a coordinated reconnaissance and intrusion attempt that must be investigated immediately.

Security Information and Event Management (SIEM) platforms are the primary tools used for correlation. They collect logs from firewalls, servers, applications, and endpoint devices, apply correlation rules, and raise alerts when suspicious patterns emerge. This dramatically reduces the time it takes to detect ongoing attacks and allows security teams to respond before serious damage occurs.

➤ **Traceback in Network Attacks**

Traceback is the process of tracing an attack back to its true origin despite the attacker's efforts to hide their identity. Attackers commonly hide using IP spoofing (faking the source IP address), routing traffic through multiple proxy servers or VPNs, or using botnets — networks of compromised machines that carry out the attack while hiding the real controller.

One common traceback method is IP traceback, where routers along the attack path embed identification information into packets. By collecting this information across routers, investigators can reconstruct the attack path step by step back to its source. Another method is log-based traceback, where each router or system maintains logs of traffic it handled, and investigators trace the traffic backward through these logs.

Traceback is essential for both incident response and legal action. Identifying the true attacker allows organizations to block the source, notify authorities, and pursue legal remedies. For example, during a large-scale Distributed Denial of Service (DDoS) attack, traceback helps identify the botnet command and control server, which can then be taken down to stop the attack entirely.

➤ **Active vs Passive Attacks**

Network attacks are broadly classified into passive attacks and active attacks based on what the attacker does to the data and the network.

Passive Attacks involve only observing or listening to network traffic without making any changes. The attacker's goal is to collect information secretly. Because no data is altered and no system is disrupted, passive attacks are very difficult to detect — the victim often has no idea they are being monitored. The two main types of passive attacks are eavesdropping, where an attacker intercepts communications between two parties to read messages or capture passwords, and traffic analysis, where even if messages are encrypted, the attacker studies the communication pattern — who is talking to whom, how often, and how much data is exchanged — to infer sensitive information.

For example, an attacker sitting in a coffee shop uses a packet sniffer on the unencrypted public Wi-Fi to capture login credentials of other users. The users have no way to notice this because their connections appear to work normally. This is a classic passive attack. Defense against passive attacks relies mainly on strong encryption — if data is encrypted, even intercepted packets reveal nothing useful.

Active Attacks involve actually doing something to the network or data — altering messages, impersonating users, disrupting services, or injecting false information. Unlike passive attacks, active attacks are more detectable because they cause noticeable disruptions or anomalies. Common types include Masquerade Attack (attacker pretends to be a legitimate user to gain unauthorized access), Replay Attack (a previously captured valid message is re-sent to trick the system — for example, resending a captured authentication token), Message Modification (intercepted messages are altered before being forwarded), and Denial of Service (flooding a server with traffic to make it unavailable to real users).

For example, in a man-in-the-middle attack, the attacker positions themselves between two communicating parties, intercepts their messages, modifies them, and forwards them — neither party realizes a third party is involved. Defense against active attacks requires firewalls, intrusion detection systems, message authentication, and digital signatures. While passive attacks steal information quietly, active attacks cause direct and often immediate harm to systems and data.

Question [3]. What is complete mediation?

Explain the concept of psychological acceptability in security systems.

Describe the Role-Based Access Control (RBAC) model and its advantages.

➤ Complete Mediation

Complete mediation is a fundamental security design principle that states every single access attempt to any resource in a system must be checked for authorization at the time of that access — without exception and without relying on cached or previously verified permissions. The system must never assume that because access was allowed the last time, it is still allowed now. This principle is important because access rights change. An employee might have access to a confidential project folder today but be removed from the project tomorrow. A system without complete mediation might cache the old permission and still allow access the next day, even though authorization was revoked. Complete mediation prevents this by rechecking at every access attempt.

For example, in an operating system, every time a process tries to read a file, the operating system checks the file's access permissions against the process's credentials — even if the same process read the same file ten times already in the same session. This ensures that any permission change takes effect immediately. Complete mediation adds a small performance overhead due to repeated checks, but the security benefit is essential — especially in systems where permissions can change frequently, like corporate document management systems or cloud platforms.

Psychological Acceptability

Psychological acceptability is a security design principle that says security mechanisms should be as easy to understand and use as possible. If a security control is too complex, too slow, or too frustrating for regular users, they will find ways to avoid it, work around it, or disable it — often creating security holes in the process. The best security is security that people actually use correctly.

This principle recognizes that humans are a critical part of any security system. A technically perfect security mechanism that nobody uses correctly is worse than a simpler mechanism that everyone follows. For example, if a password policy requires a 20-character password with symbols, numbers, and mixed case that changes every 30 days, most users will write it on a sticky note under their keyboard, use predictable patterns, or reuse the same password everywhere — all of which create major vulnerabilities.

A better design applies psychological acceptability — use single sign-on (SSO) so users log in once and access multiple systems, use fingerprint or face recognition instead of complex passwords where possible, and make security prompts simple and clear rather than full of technical jargon. When security feels natural and unobtrusive, users comply with it consistently. Security designers must always consider the human element alongside the technical one — because the weakest link in any security system is almost always human behavior.

Role-Based Access Control (RBAC) Model and Advantages

Role-Based Access Control, or RBAC, is an access control model in which permissions are assigned to roles rather than directly to individual users. Users are then assigned to roles based on their job function. This indirect approach — user gets role, role has permissions — makes managing access in large organizations much simpler and more consistent.

For example, in a university system, roles might include Student, Faculty, Exam Controller, and Administrator. The Faculty role has permissions to upload grades, view student attendance, and access course materials. The Student role has permissions to view their own grades and download study materials but cannot modify any records. The Exam Controller role has permissions to generate hall tickets and publish results. When a new lecturer joins the university, the administrator simply assigns them to the Faculty role and they immediately get all the right permissions — no need to set up individual access rights one by one.

RBAC works on three core components: Users are the people who need access. Roles are named job functions that bundle a set of permissions together. Permissions define what operations are allowed on which resources. A user can hold multiple roles if needed, and roles can be organized in hierarchies — a Senior Manager role might inherit all permissions of the Manager role plus additional ones.

The advantages of RBAC are significant. First, administration becomes much simpler — managing 20 roles is far easier than managing individual permissions for 5000 employees. Second, it enforces least privilege naturally — each role only has the permissions needed for that job function. Third, when an employee changes departments, only their role assignment needs to change, not dozens of individual permissions. Fourth, when an employee leaves, revoking their role immediately removes all their access in one step. Fifth, RBAC provides clear audit trails — security teams can review which roles have which permissions and quickly identify any over-privileged roles. Sixth, RBAC helps organizations meet compliance requirements like ISO 27001 and GDPR by demonstrating that access is systematically controlled and documented.

SET – II

Question [4]. What are Message Authentication Codes (MAC)?

Explain their role in secure communication. Explain the importance of cybersecurity education and awareness training in organizations. Explain the concept of TEMPEST.

➤ Message Authentication Codes (MAC)

A Message Authentication Code (MAC) is a short piece of data generated from a message and a secret key using a cryptographic algorithm. It is attached to a message before sending so that the receiver can verify both that the message came from the genuine sender and that it has not been altered during transmission. Both the sender and receiver share the same secret key — only they can generate or verify the MAC correctly.

➤ **Role of MAC in Secure Communication**

MAC provides two critical security services simultaneously: authentication and integrity. Authentication confirms that the message was created by someone who knows the shared secret key — meaning it came from the legitimate sender. Integrity confirms that the message content was not changed in transit. The receiver recalculates the MAC using the received message and the shared key. If this calculated value matches the MAC that arrived with the message, everything is authentic. If even one character of the message was altered, the recalculated MAC will not match, and the receiver knows the message was tampered with.

MAC is widely used in financial transactions, VPN tunnels, and network protocol security. For example, in internet banking, every transaction message is protected with a MAC to ensure that an attacker cannot intercept and modify the payment amount or the recipient account number without detection.

Cybersecurity Education and Awareness Training

Technical security tools like firewalls, antivirus software, and encryption are essential, but they cannot fully protect an organization if its employees do not understand basic cybersecurity practices. Human error remains the leading cause of security breaches worldwide. Phishing attacks, weak passwords, unintentional data sharing, and mishandling of sensitive information are all caused by insufficient awareness — not by technical failures.

Cybersecurity education teaches employees to recognize threats like phishing emails, suspicious attachments, and fake login pages. For example, an employee who understands phishing will not click a link in an email claiming 'Your account has been compromised — click here to verify.' Without this training, that same employee might click the link, enter their credentials, and unknowingly hand them to an attacker.

Regular awareness training, simulated phishing exercises, password hygiene workshops, and clear security policies create a security-conscious culture across the organization. When every employee understands their role in protecting data — locking screens when away, reporting suspicious activity, not sharing passwords — the organization becomes significantly harder to attack. Investment in awareness training consistently delivers a high return by preventing costly incidents that technical tools alone cannot stop.

➤ **TEMPEST**

TEMPEST is a classified code name used by government and military organizations, particularly in the USA and NATO, to refer to the study and control of unintentional electromagnetic emissions produced by electronic devices during normal operation. Every electronic device — a computer monitor, a keyboard, a printer, or a network cable — emits faint electromagnetic signals as a side effect of its electrical activity. TEMPEST is concerned with the possibility that these emissions can be captured from a distance and analyzed to reconstruct the data being processed.

For example, an older CRT monitor emits electromagnetic signals that correspond directly to the pixels being displayed. A specially equipped attacker positioned outside a building can capture these signals using a directional antenna and reconstruct a readable image of what is on the screen — without ever physically accessing the device or the network. Similarly, the

electromagnetic emissions from keyboard keystrokes can potentially be captured and decoded to reveal what a user is typing.

TEMPEST countermeasures include shielding devices and rooms with special materials that block electromagnetic leakage (called Faraday cages), using low-emission certified devices designed to minimize these signals, maintaining physical distance between sensitive equipment and building boundaries, and using fiber optic cables instead of electrical cables for data transmission where feasible. Government agencies, intelligence organizations, and military installations that handle classified information are required to use TEMPEST-compliant equipment to prevent this form of side-channel attack.

Question [5]. Explain buffer overflow attacks and how they affect operating system security. Explain different types of malwares and their impact.

➤ Buffer Overflow Attacks and OS Security

A buffer is a fixed-size area in memory used to temporarily hold data while it is being processed. When a program accepts input from a user or another source, it stores that input in a buffer. A buffer overflow happens when the amount of data written into the buffer exceeds its capacity — the extra data spills over into adjacent memory areas that hold other data or program instructions.

Attackers deliberately exploit this by crafting input that is much larger than the buffer can hold. The overflowing data can overwrite the return address stored on the call stack — the address that tells the program where to continue execution after a function finishes. By carefully controlling what the overflow data contains, the attacker can replace the return address with the address of their own malicious code, causing the program to execute that code instead of returning normally.

The impact on operating system security is severe. If the vulnerable program is running with elevated privileges (such as administrator or root), the attacker's injected code runs with those same privileges — effectively giving the attacker complete control over the operating system. They can install backdoors, create new admin accounts, delete logs to cover their tracks, or deploy ransomware. Buffer overflows have been behind some of the most damaging cyberattacks in history, including the Morris Worm in 1988, which was one of the first major internet attacks.

Modern defenses against buffer overflows include stack canaries (special values placed in the stack that are checked before a function returns — if the value has changed, an overflow is detected), Address Space Layout Randomization (ASLR, which randomizes where code and data are loaded in memory making it hard for attackers to predict where to redirect execution), Data Execution Prevention (DEP/NX, which marks memory regions as either executable or writable but not both — preventing injected data from being executed as code), and safe programming practices like always checking input length before storing it and using memory-safe programming languages.

➤ Types of Malware and Their Impact

Malware is any software intentionally designed to harm a computer system, network, or its users. It comes in many forms, each with its own method of spreading and its own type of damage.

Virus: A virus is malicious code that attaches itself to a legitimate file or program. It spreads when an infected file is shared and executed. Viruses can delete or corrupt files, slow down systems, and spread through email attachments or USB drives. The ILOVEYOU virus of 2000 spread through email and caused billions of dollars in damage by overwriting files on infected machines.

Worm: Unlike a virus, a worm does not need to attach to a host file — it spreads independently through networks by exploiting vulnerabilities. Worms can replicate rapidly, consuming network bandwidth and crashing servers. The WannaCry ransomware worm of 2017 exploited a Windows vulnerability and spread to over 200,000 computers in 150 countries within days.

Trojan Horse: A Trojan disguises itself as a legitimate, useful program to trick users into installing it. Once installed, it performs malicious actions in the background — opening backdoors, stealing data, or downloading additional malware. For example, a fake video player download that secretly installs a remote access tool giving the attacker full control of the victim's computer.

Ransomware: Ransomware encrypts the victim's files and demands a ransom payment in exchange for the decryption key. Hospitals, government agencies, and large corporations have been paralyzed by ransomware attacks. Even if the ransom is paid, there is no guarantee the files will be restored. The financial and operational impact can be enormous — some organizations have paid millions of dollars and still lost critical data.

Spyware: Spyware secretly monitors user activity — recording keystrokes, capturing screenshots, tracking browser history, and collecting login credentials — and sends this information to the attacker without the user's knowledge. **Adware** floods the user with unwanted advertisements and may also collect browsing data. **Rootkit:** A rootkit embeds itself deep within the operating system and hides the presence of other malware. It is extremely difficult to detect and remove because it can intercept and modify the system calls used by security tools. **Keylogger:** Records every keystroke made by the user and sends the captured data to the attacker, enabling theft of passwords, credit card numbers, and confidential messages.

Question [6]. Explain the working of the ARP protocol. Describe the role of cryptography in web security. Explain IPSec and SSL protocols and their role in network security.

➤ Working of ARP Protocol

ARP stands for Address Resolution Protocol. It operates at the data link layer and solves a very specific problem: in a local area network, communication between devices uses MAC (Media Access Control) addresses, but higher-level protocols like IP use logical IP addresses. When a device wants to send data to another device on the same network and knows only its IP address, it needs to find the corresponding MAC address. ARP handles this mapping.

The process works as follows. The sending device first checks its local ARP cache — a table of recently resolved IP-to-MAC mappings stored in memory. If the mapping is found and still valid, it uses that MAC address directly. If not found, it broadcasts an ARP Request packet to all devices on the network. The broadcast message essentially says: 'Who has IP address 192.168.1.50? Please tell me your MAC address.' Every device on the network receives this broadcast, but only the device with that IP address replies with an ARP Reply — a unicast message containing its MAC address. The original device stores this mapping in its ARP cache for future use and then sends the data using the resolved MAC address.

ARP is simple and efficient but has a well-known vulnerability: ARP Spoofing. Because ARP has no authentication mechanism, an attacker can send fake ARP Reply messages claiming that their MAC address corresponds to another device's IP address. This poisons the ARP caches of other devices on the network, redirecting their traffic through the attacker — enabling man-in-the-middle attacks, traffic interception, and denial of service.

Role of Cryptography in Web Security

The internet is an open, public network where data travels through many intermediate systems between sender and receiver. Without protection, any device along this path could intercept, read, or alter the data. Cryptography is what makes secure communication over the internet possible by transforming data into a form that is unreadable without the correct key.

The most visible application of cryptography in web security is HTTPS — the secure version of HTTP used by all modern websites. HTTPS uses TLS (Transport Layer Security) to establish an encrypted connection between a user's browser and the web server. This involves asymmetric cryptography during the handshake phase (the server presents a digital certificate to prove its identity, and both sides agree on encryption parameters) and then symmetric cryptography for the actual data transfer (faster for large amounts of data). This means that even if someone intercepts the network traffic, they see only encrypted gibberish.

Beyond HTTPS, cryptography protects passwords through hashing — stored passwords are never saved as plain text but as one-way hash values, so a database breach does not immediately expose user passwords. Digital signatures verify the authenticity of software downloads, emails, and documents. Public Key Infrastructure (PKI) with Certificate Authorities ensures that websites are who they claim to be, preventing impersonation attacks. In short, without cryptography, secure online banking, shopping, healthcare, and communication would be completely impossible.

➤ IPsec and SSL/TLS Protocols

IPsec (Internet Protocol Security) is a suite of protocols designed to secure IP communications by authenticating and encrypting every IP packet in a communication session. It operates at the network layer (Layer 3) of the OSI model, which means it works transparently beneath the application layer — any application using IP benefits from IPsec protection without needing modification.

IPsec uses two main sub-protocols. Authentication Header (AH) provides data integrity and source authentication — it proves the packet came from the legitimate sender and has not been altered — but does not encrypt the data. Encapsulating Security Payload (ESP) provides both

encryption and authentication, making it the more commonly used option for full security. IPsec can operate in two modes: Transport Mode, where only the data payload of the IP packet is protected (used for direct host-to-host communication), and Tunnel Mode, where the entire original IP packet is encrypted and wrapped inside a new IP packet (used in VPNs to securely connect two networks across the internet). IPsec is the standard protocol used in corporate VPNs, allowing employees to securely access company resources from home as if they were in the office.

SSL (Secure Sockets Layer) and its successor TLS (Transport Layer Security) operate at the transport layer (Layer 4) and secure application-level communications. While SSL is the older name and is now deprecated, TLS is the current standard — though both terms are still used interchangeably. SSL/TLS is the technology behind HTTPS and is also used to secure email (SMTPS, IMAPS) and other protocols.

The SSL/TLS handshake process establishes a secure session: the client connects to the server, the server presents its digital certificate issued by a trusted Certificate Authority, the client verifies the certificate, both parties negotiate the cipher suite to use, and then session keys are exchanged. After the handshake, all communication is encrypted using symmetric encryption for efficiency. The key difference between IPsec and SSL/TLS is their layer of operation and typical use case. IPsec works at the network level and is ideal for securing all traffic between networks or hosts — making it perfect for VPNs. SSL/TLS works at the application level and is ideal for securing specific application communications like web browsing and email. In practice, both are used in complementary ways to provide layered security across different parts of a network infrastructure.